



Mobil Uygulama Güvenliğini Farklı Perspektiflerden Okumak



Ahmethan Gültekin
#gdg2025

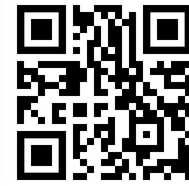


Ahmethan Gültekin

mobile application security researcher
founder of **Byteria**



ahmeth4n.github.io



byterialab.com

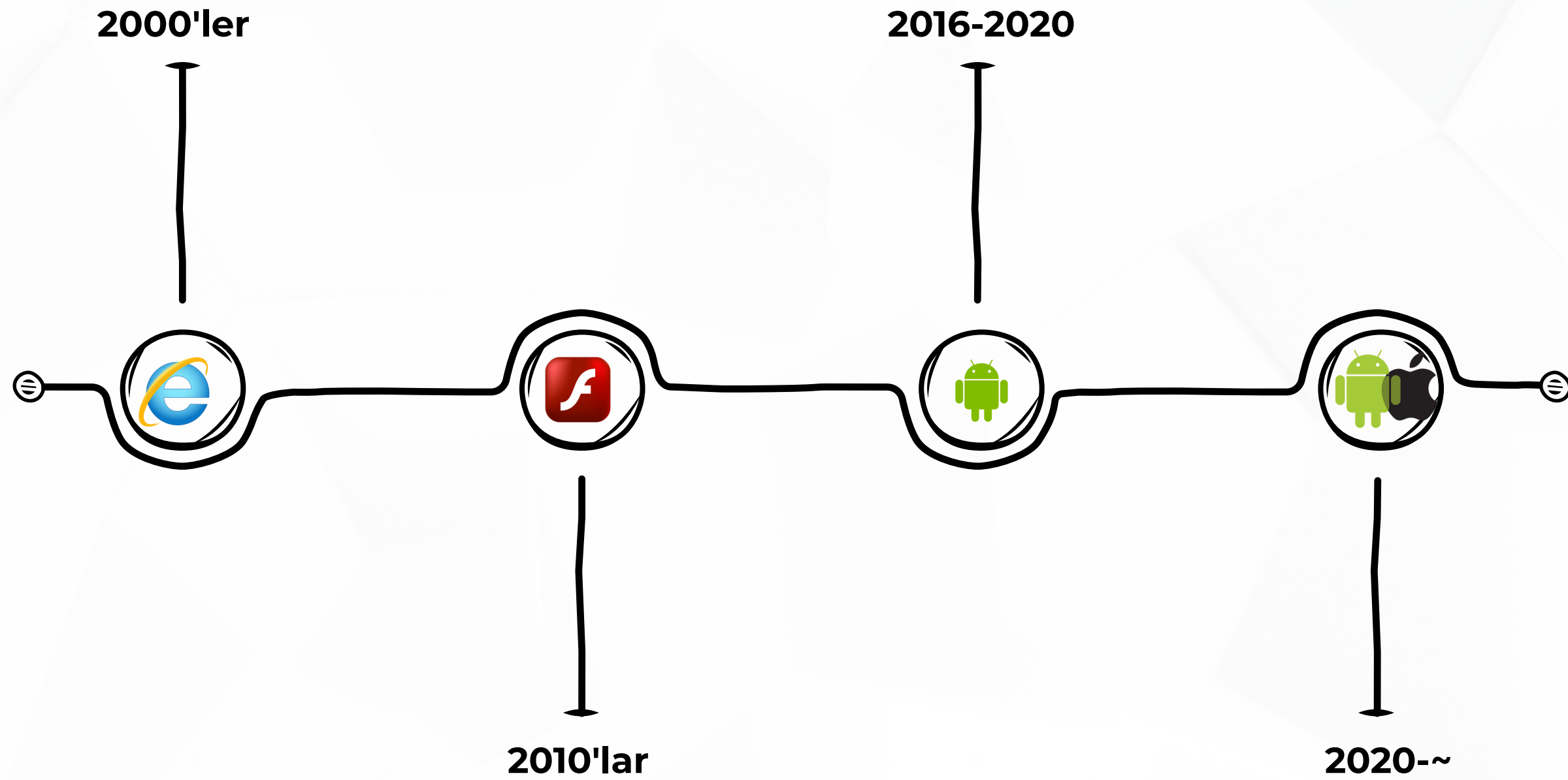
Konular:

- Zafiyetlerin Evrimi
- Saldırgan Gözünden Mobil Uygulama Güvenliği
- Gerçek Hayattan Örnekler: Modern Atakların Anatomisi
- Öneri / Tavsiyeler
- Kapanış

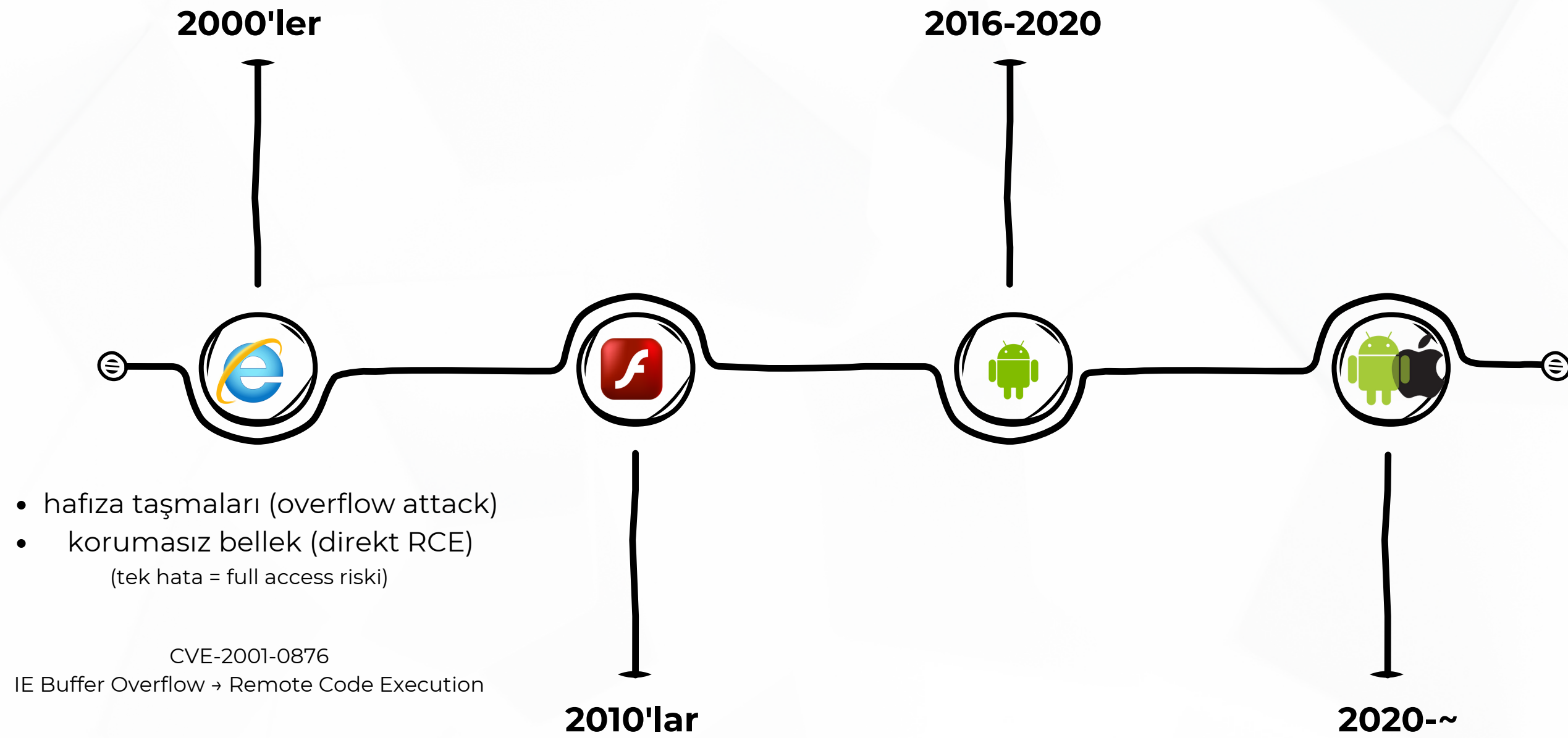
Sunum Dosyaları:

<https://github.com/Ahmeth4n/talks>

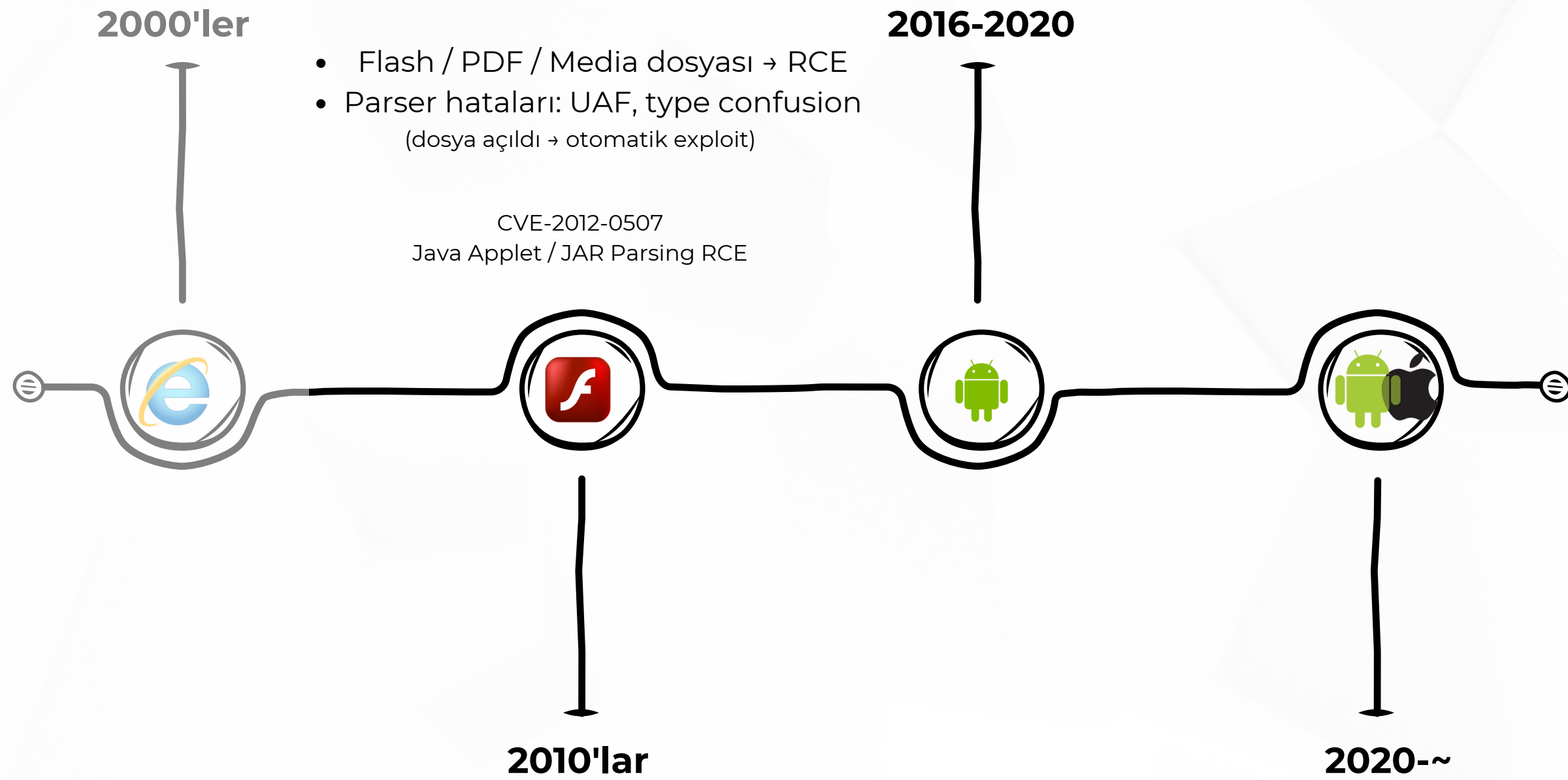
Zafiyetlerin Evrimi



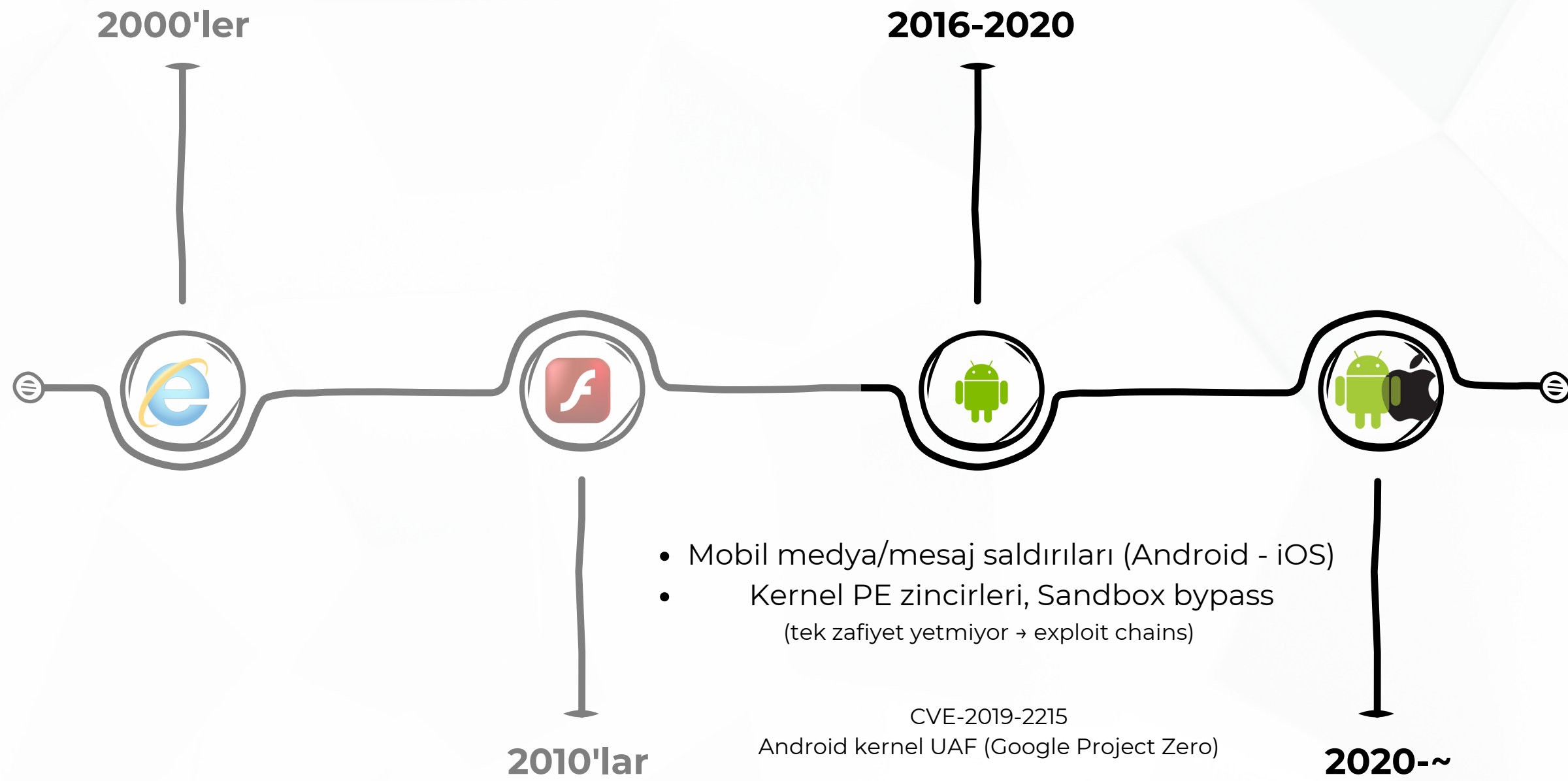
Zafiyetlerin Evrimi



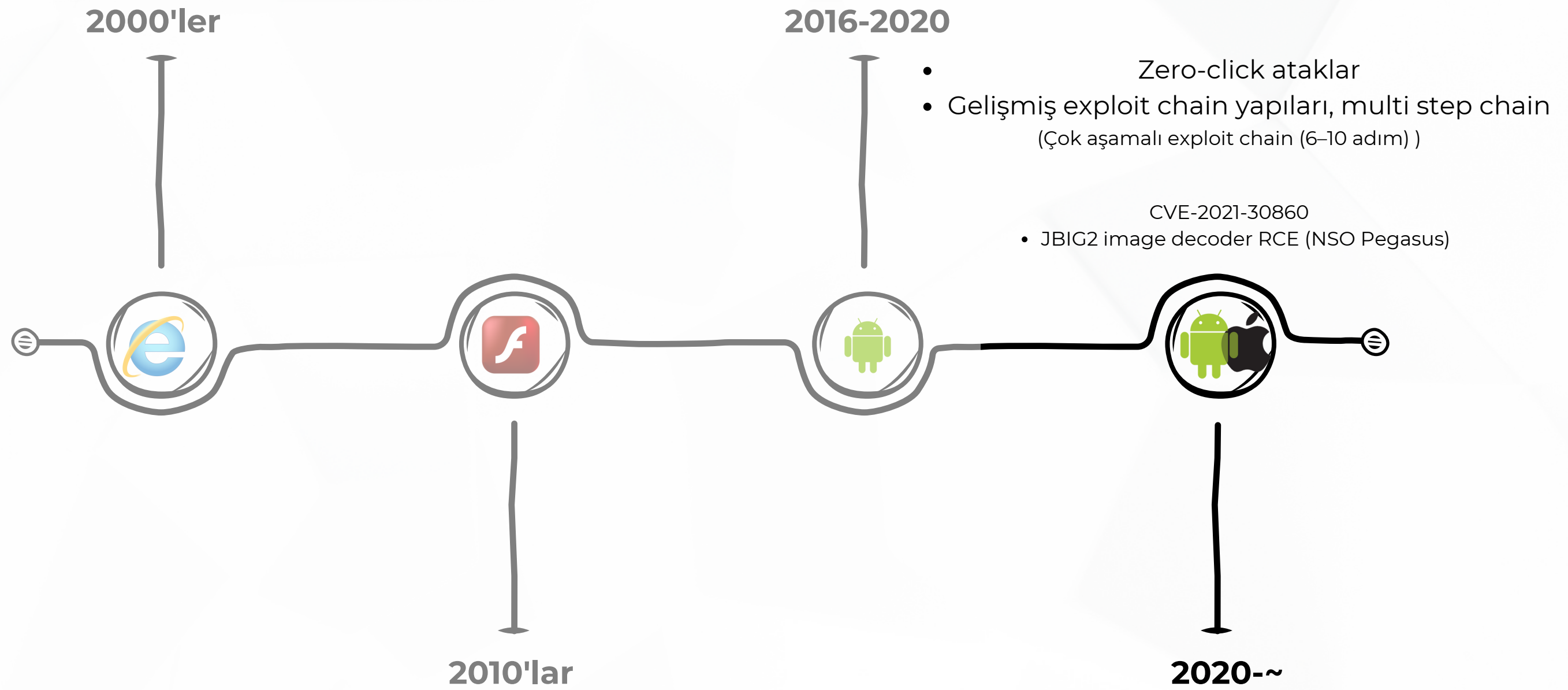
Zafiyetlerin Evrimi

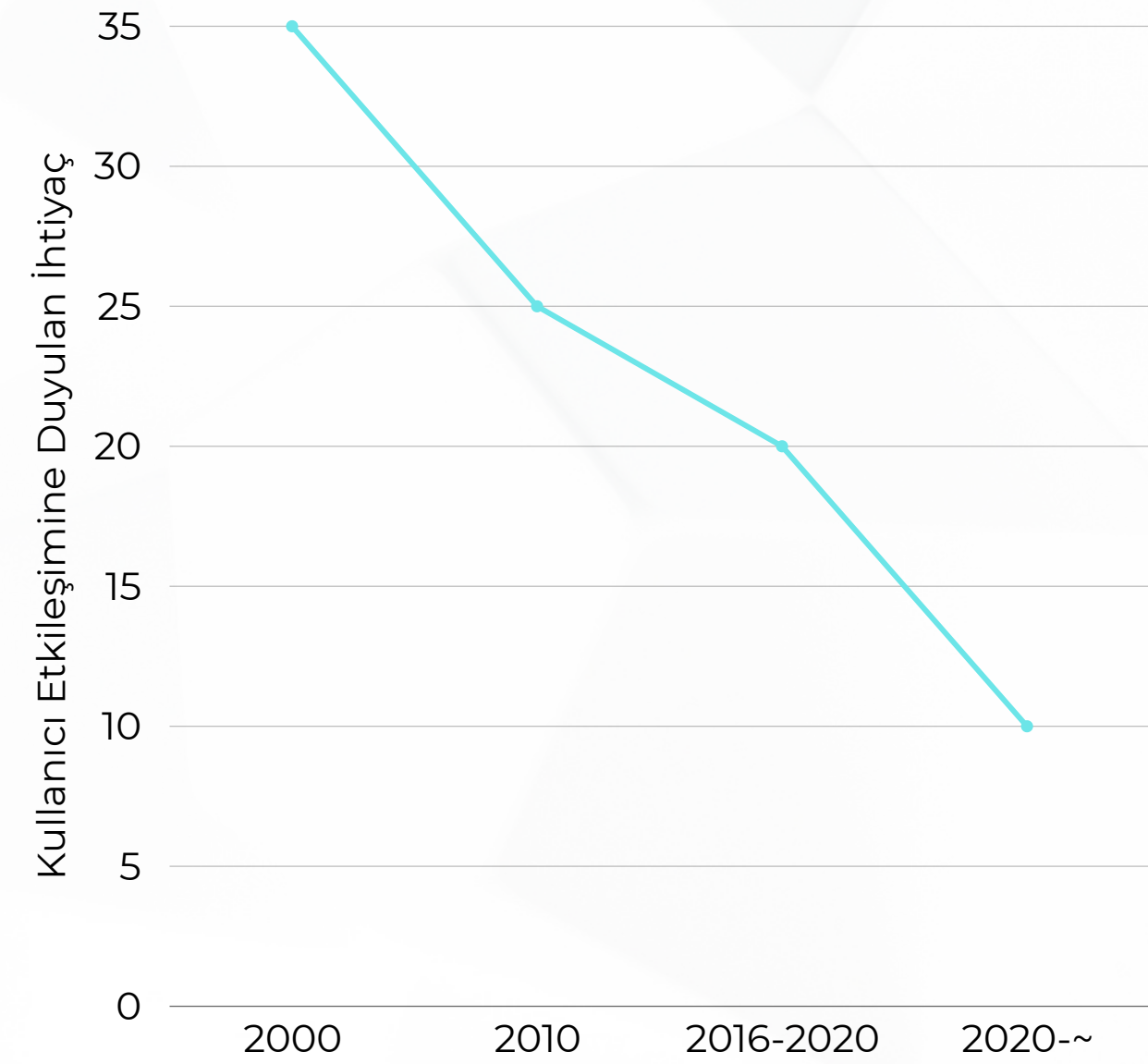
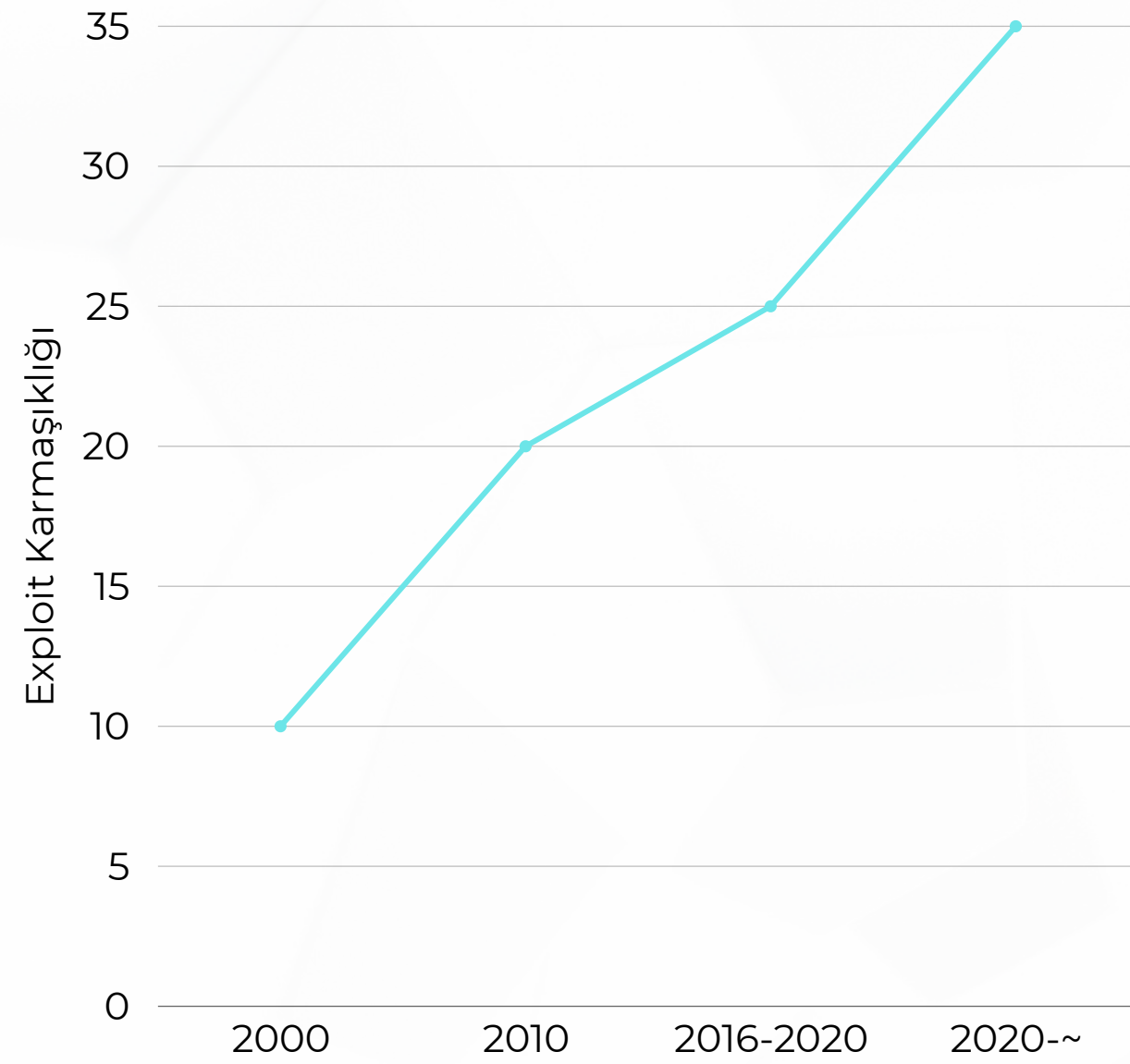


Zafiyetlerin Evrimi



Zafiyetlerin Evrimi





Karşılaştırma

2000'ler

- yazılım geliştirme açısından kaynak çok az
- güvenlik algısı henüz oluşmamış
- yazılımın geliştirildiği ortam çeşitliliği çok az
- teknoloji bugünkü kadar yaygın değil (telefonlar, akıllı ev aletleri)
- yazılımcılar da saldırganlar da kısıtlı bilgi düzeyinde

2020 - ~

- her konudan kaynak çok fazla (yazılım - siber güvenlik)
- her güvenlik olayı için ayrı uzmanlık alanları (devsecops, mobile, web)
- çok fazla ekosistem çeşitliliği (android,ios,macos,windows,linux v.b)
- teknoloji her yerde
- AI araçları ile bilinmeyen konuda bile yazılım geliştirebilme / özellik ekleyebilme imkanı

Karşılaştırma

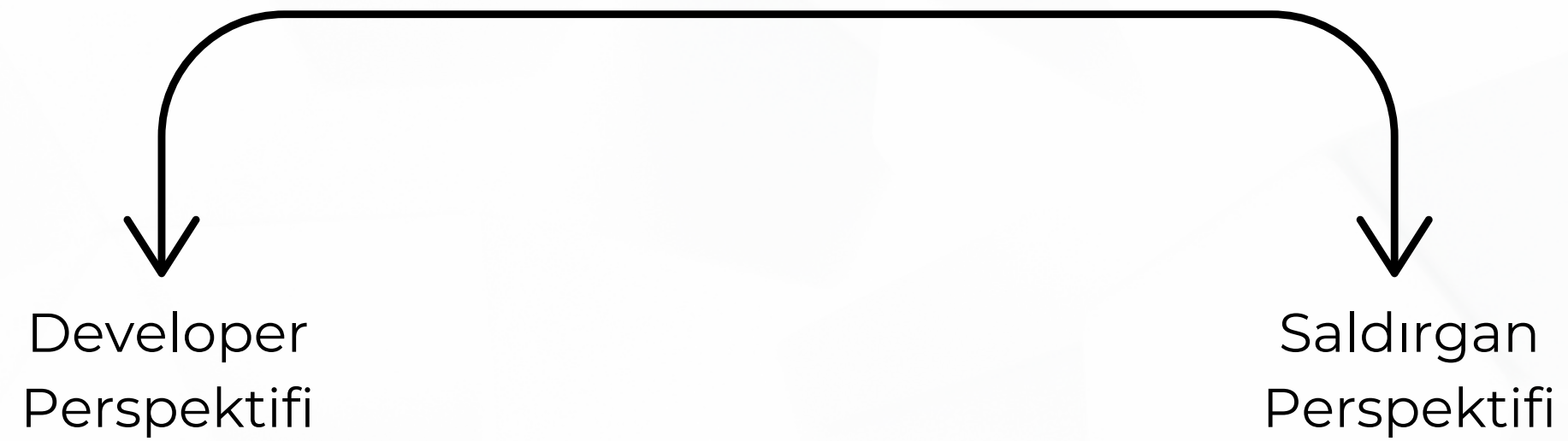
2000'ler 

- yazılım geliştirme açısından kaynak çok az
- güvenlik algısı henüz oluşmamış
- yazılımın geliştirildiği ortam çeşitliliği çok az
- teknoloji bugünkü kadar yaygın değil (telefonlar, akıllı ev aletleri)
- yazılımcılar da saldırganlar da kısıtlı bilgi düzeyinde

2020 - ~ 

- her konudan kaynak çok fazla (yazılım - siber güvenlik)
- her güvenlik olayı için ayrı uzmanlık alanları (devsecops, mobile, IoT)
- çok fazla ekosistem çeşitliliği (android,ios,macos,windows,linux v.b)
- teknoloji her yerde
- AI araçları ile bilinmeyen konuda bile yazılım geliştirebilme / özellik ekleyebilme imkanı

Farklı Perspektifler



Developer Perspektifi

- “Input’u kontrol ettim, sorun yok”
- “Bu data çok küçük, sensitive bir veri değil”
- “Bu data server’dan geliyor, güvenilir”
- “Bu fonksiyon local çalışıyor, dışarıya açık değil.”
- “Bu özellik kullanıcı deneyimi için. Herhangi bir atak vektörü yok.”
- “Şimdi ekleyeyim, kod çalışsın, sonra düzeltirim.”

Developer Perspektifi

- “Input’u kontrol ettim, sorun yok”
CVE-2018-13989 - Grundig Smart Inter@ctive 3.0 - CSRF
- “Bu data çok küçük, sensitive bir veri değil”
- “Bu data server’dan geliyor, güvenilir”
- “Bu fonksiyon local çalışıyor, dışarıya açık değil.”
- “Bu özellik kullanıcı deneyimi için. Herhangi bir atak vektörü yok.”
- “Şimdi ekleyeyim, kod çalışsın, sonra düzeltirim.”

Developer Perspektifi

- “Input’u kontrol ettim, sorun yok”
CVE-2018-13989 - Grundig Smart Inter@ctive 3.0 - CSRF
- “Bu data çok küçük, sensitive bir veri değil”
CVE-2020-0022 – BlueFrag (Android Bluetooth RCE)
- “Bu data server’dan geliyor, güvenilir”
- “Bu fonksiyon local çalışıyor, dışarıya açık değil.”
- “Bu özellik kullanıcı deneyimi için. Herhangi bir atak vektörü yok.”
- “Şimdi ekleyeyim, kod çalışsın, sonra düzeltirim.”

Developer Perspektifi

- “Input’u kontrol ettim, sorun yok”
CVE-2018-13989 - Grundig Smart Inter@ctive 3.0 - CSRF
- “Bu data çok küçük, sensitive bir veri değil”
CVE-2020-0022 – BlueFrag (Android Bluetooth RCE)
- “Bu data server’dan geliyor, güvenilir”
CVE-2019-3568 — WhatsApp VOIP Buffer Overflow (Pegasus)
- “Bu fonksiyon local çalışıyor, dışarıya açık değil.”
- “Bu özellik kullanıcı deneyimi için. Herhangi bir atak vektörü yok.”
- “Şimdi ekleyeyim, kod çalışsın, sonra düzeltirim.”

Developer Perspektifi

- “Input’u kontrol ettim, sorun yok”
CVE-2018-13989 - Grundig Smart Inter@ctive 3.0 - CSRF
- “Bu data çok küçük, sensitive bir veri değil”
CVE-2020-0022 – BlueFrag (Android Bluetooth RCE)
- “Bu data server’dan geliyor, güvenilir”
CVE-2019-3568 — WhatsApp VOIP Buffer Overflow (Pegasus)
- “Bu fonksiyon local çalışıyor, dışarıya açık değil.”
CVE-2020-8913 – Google Play Core Local Module Load RCE
- “Bu özellik kullanıcı deneyimi için. Herhangi bir atak vektörü yok.”
- “Şimdi ekleyeyim, kod çalışsın, sonra düzeltirim.”

Developer Perspektifi

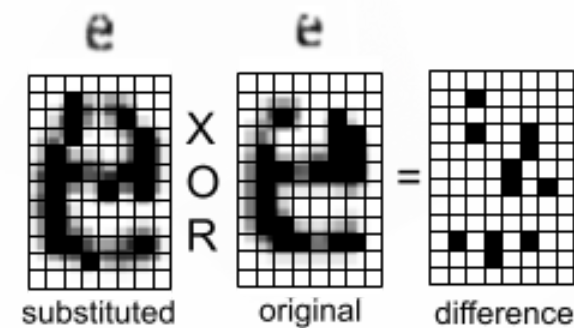
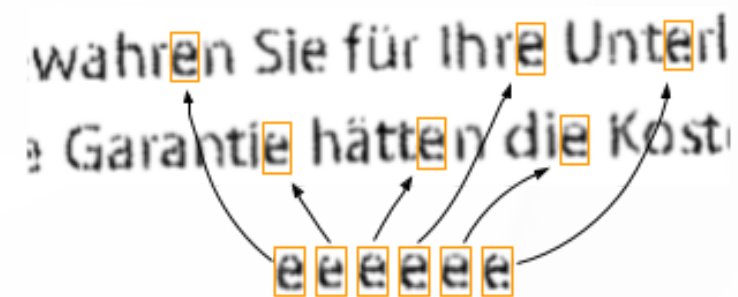
- “Input’u kontrol ettim, sorun yok”
CVE-2018-13989 - Grundig Smart Inter@ctive 3.0 - CSRF
- “Bu data çok küçük, sensitive bir veri değil”
CVE-2020-0022 – BlueFrag (Android Bluetooth RCE)
- “Bu data server’dan geliyor, güvenilir”
CVE-2019-3568 — WhatsApp VOIP Buffer Overflow (Pegasus)
- “Bu fonksiyon local çalışıyor, dışarıya açık değil.”
CVE-2020-8913 – Google Play Core Local Module Load RCE
- “Bu özellik kullanıcı deneyimi için. Herhangi bir atak vektörü yok.”
CVE-2015-3864 — Android Stagefright MMS RCE (Zero-click)
- “Şimdi ekleyeyim, kod çalışsın, sonra düzeltirim.”

Developer Perspektifi

- “Input’u kontrol ettim, sorun yok”
CVE-2018-13989 - Grundig Smart Inter@ctive 3.0 - CSRF
- “Bu data çok küçük, sensitive bir veri değil”
CVE-2020-0022 – BlueFrag (Android Bluetooth RCE)
- “Bu data server’dan geliyor, güvenilir”
CVE-2019-3568 — WhatsApp VOIP Buffer Overflow (Pegasus)
- “Bu fonksiyon local çalışıyor, dışarıya açık değil.”
CVE-2020-8913 – Google Play Core Local Module Load RCE
- “Bu özellik kullanıcı deneyimi için. Herhangi bir atak vektörü yok.”
CVE-2015-3864 — Android Stagefright MMS RCE (Zero-click)
- “Şimdi ekleyeyim, kod çalışsın, sonra düzeltirim.”
CVE-2024-12651 — HGS Mobile Unauthorized Parameter Control (Data Exposure)

Saldırgan Perspektifi (CVE-2021-30860)

- iMessage → MMS → RCE
- JBIG2 integer overflow (OOB write)
- Heap üzerinde bit-manipülasyonu
- Mantık kapıları: AND/OR/XOR/XNOR → NAND
- 70.000 segment = mini CPU (NAND devre ile)
- Zero-click



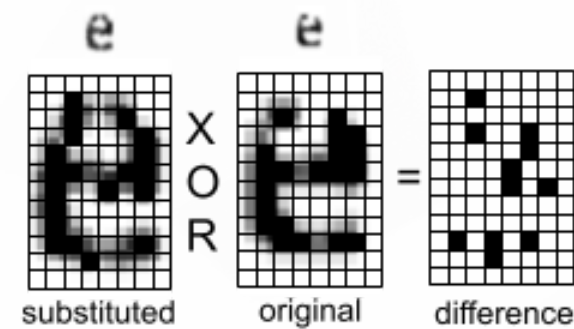
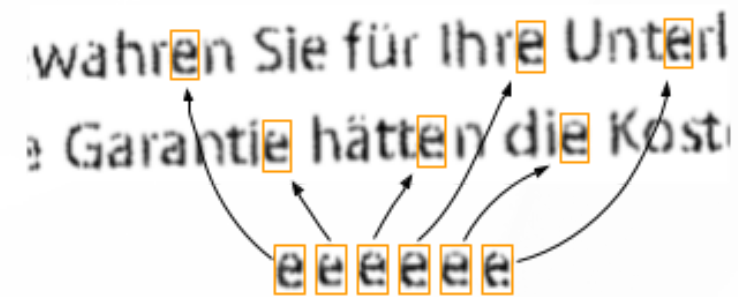
```
Guint numSyms; // (1)

numSyms = 0;
for (i = 0; i < nRefSegs; ++i) {
    if ((seg = findSegment(refSegs[i]))) {
        if (seg->getType() == jbig2SegSymbolDict) {
            numSyms += ((JBIG2SymbolDict *)seg)->getSize(); // (2)
        } else if (seg->getType() == jbig2SegCodeTable) {
            codeTables->append(seg);
        }
    } else {
        error(errSyntaxError, getPos(),
            "Invalid segment reference in JBIG2 text region");
        delete codeTables;
        return;
    }
}
...
// get the symbol bitmaps
syms = (JBIG2Bitmap **)gmallocn(numSyms, sizeof(JBIG2Bitmap *)); //
(3)

kk = 0;
for (i = 0; i < nRefSegs; ++i) {
    if ((seg = findSegment(refSegs[i]))) {
        if (seg->getType() == jbig2SegSymbolDict) {
            symbolDict = (JBIG2SymbolDict *)seg;
            for (k = 0; k < symbolDict->getSize(); ++k) {
                syms[kk++] = symbolDict->getBitmap(k); // (4)
            }
        }
    }
}
```

Saldırgan Perspektifi (CVE-2021-30860)

- iMessage → MMS → RCE
- JBIG2 integer overflow (OOB write)
- Heap üzerinde bit-manipülasyonu
- Mantık kapıları: AND/OR/XOR/XNOR → NAND
- 70.000 segment = mini CPU (NAND devre ile)
- Zero-click



```

Guint numSyms; // (1)

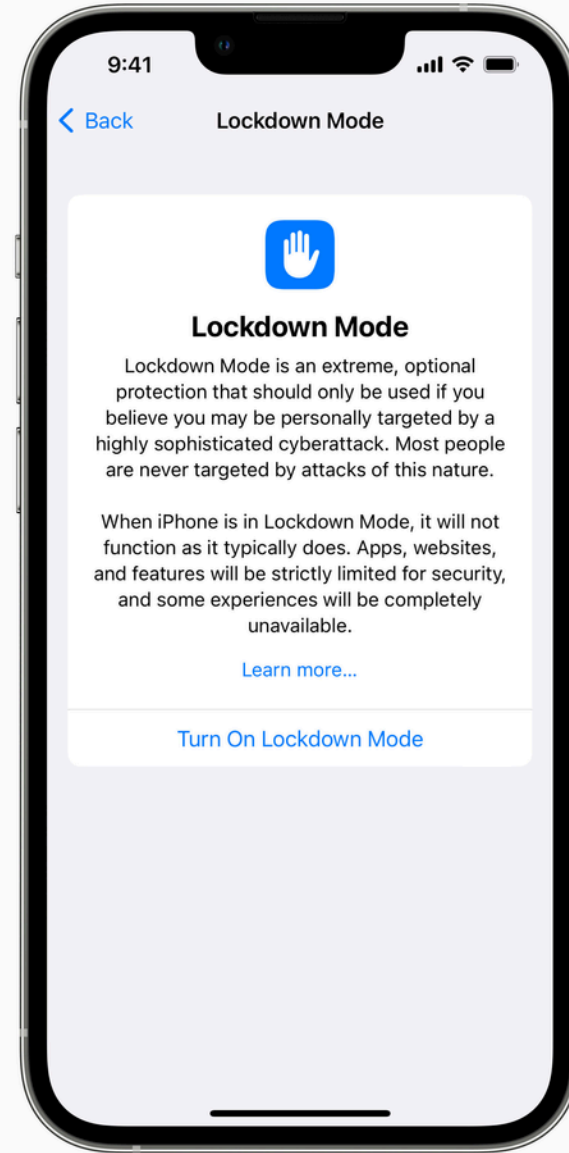
numSyms = 0;
for (i = 0; i < nRefSegs; ++i) {
    if ((seg = findSegment(refSegs[i]))) {
        if (seg->getType() == jbig2SegSymbolDict) {
            numSyms += ((JBIG2SymbolDict *)seg)->getSize(); // (2)
        } else if (seg->getType() == jbig2SegCodeTable) {
            codeTables->append(seg);
        }
    } else {
        error(errSyntaxError, getPos(),
            "Invalid segment reference in JBIG2 text region");
        delete codeTables;
        return;
    }
}
...
// get the symbol bitmaps
syms = (JBIG2Bitmap **)gmallocn(numSyms, sizeof(JBIG2Bitmap)
(3)

kk = 0;
for (i = 0; i < nRefSegs; ++i) {
    if ((seg = findSegment(refSegs[i]))) {
        if (seg->getType() == jbig2SegSymbolDict) {
            symbolDict = (JBIG2SymbolDict *)seg;
            for (k = 0; k < symbolDict->getSize(); ++k) {
                syms[kk++] = symbolDict->getBitmap(k); // (4)
            }
        }
    }
}

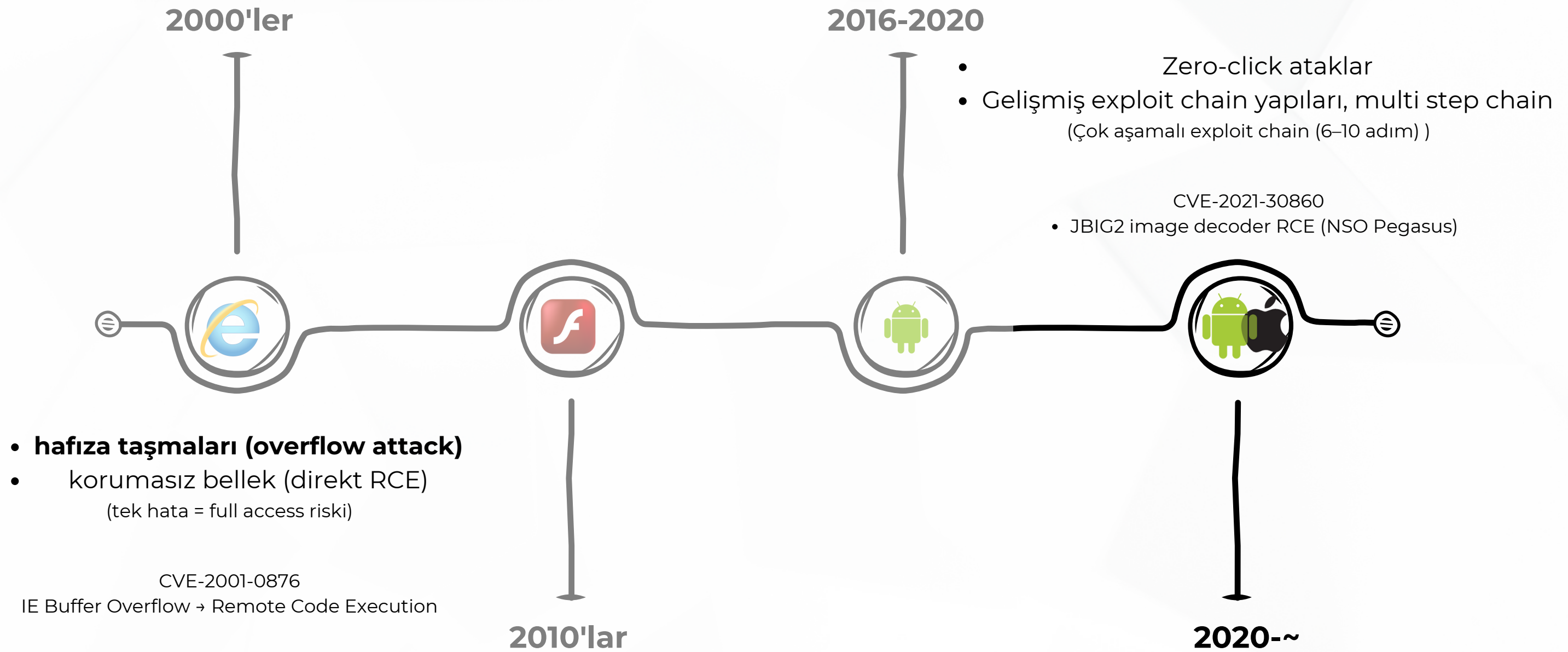
```

Operatör	Kullanım Amacı
-----	-----
AND	Ortak bitleri almak
OR	Bitleri birleştirmek / eklemek
XOR	İki glif arasındaki farkı bulmak
XNOR	Benzer bitleri tespit etmek
SHIFT	Bölgeyi kaydırmak / konum değiştirmek
bit-set	Biti 1 yapmak
bit-clear	Biti 0 yapmak
region-copy	Bir bölgeyi başka yere kopyalamak

Sonuç:

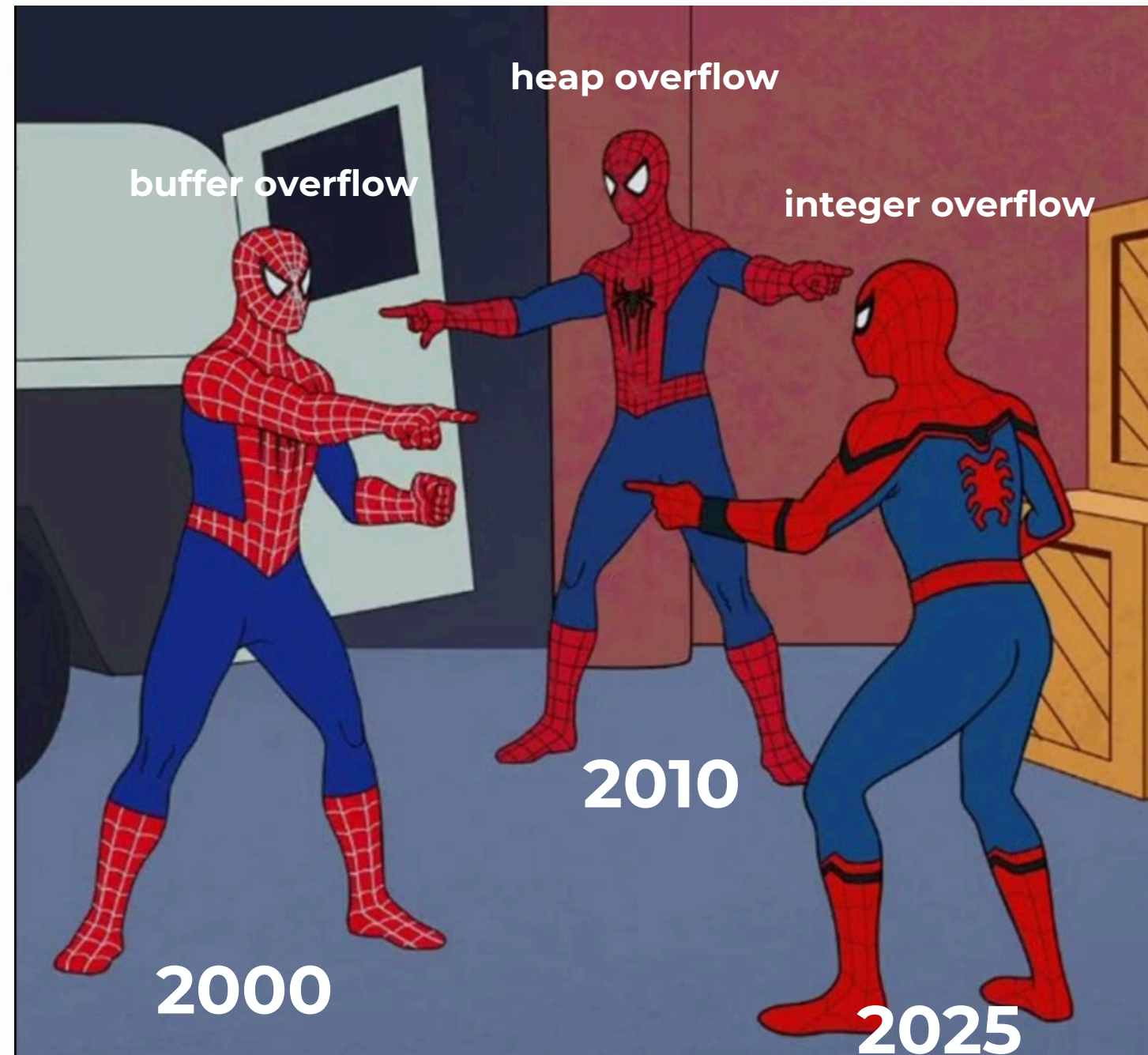


Saldırgan Perspektifi (CVE-2021-30860)



|| BYTERIA

2000 - 2010 - 2025



Sonuç:

- **“Input’u kontrol ettim” demek yetmez. →**

Input sadece kullanıcıdan gelen veri değildir. Parser’lar, decoder’lar ve 3rd-party SDK’lar dahil uygulamanın işlediği tüm veri akışları saldırı yüzeyidir

- **“Küçük veri → küçük risk” yanılgısı →**

BlueFrag, Stagefright, FORCEDENTRY gibi saldırılar küçük bir payload ile milyonlarca cihazı ele geçirdi. Veri boyutu → risk seviyesi değildir.

- **“Data server’den geliyor, güvenilir” diye düşünme →**

Sunucudan gelen veri her zaman potansiyel exploit yüzeyidir. Örnek: WhatsApp VOIP RCE
Server kaynaklı veriyi de untrusted olarak işleme

- **“Sonra düzeltirim” dediğin her teknik borç → exploit zincirine dönüşür →**

HGS zafiyeti gibi “küçük” gördüğün şeyler data exposure, privilege escalation ve identity spoofing’e dönüşebilir.

- **3rd-party SDK’lar, dependency’ler, open-source paketleri →**

Güncel tut, audit et, sandbox et. Geçmişte milyonları etkileyen zafiyetlerin çoğu 3rd-party dependency kaynaklıydı. (Log4J, FORCEDENTRY)



Final:

Dinlediğiniz için teşekkürler :)

<https://github.com/Ahmeth4n/talks>

ahmethan@byterialab.com

<https://byterialab.com>